

Audit Keamanan AbsensiPro

Ringkasan untuk konsultasi teknis | 23 Agustus 2026

Kesimpulan singkat: project sudah memiliki fondasi SaaS multi-tenant dan beberapa lapisan keamanan, tetapi belum sepenuhnya bebas dari penyimpanan browser. Data utama diarahkan ke Supabase, sedangkan cache, antrean offline, preferensi, rate limit, audit lokal, dan session masih dapat berada di perangkat.

Keamanan yang Digunakan

Lapisan	Implementasi	Status
Authentication	Supabase Auth untuk login, register, session, logout, reset password.	Aktif
Authorization	Role <code>admin</code> , <code>hrd</code> , <code>karyawan</code> / <code>magang</code> dan pemeriksaan akses.	Aktif
Multi-tenant	<code>company_id</code> pada data dan filter tenant pada query.	Aktif
Database security	Supabase Row Level Security, policy berbasis user, tenant, dan role.	Aktif jika SQL sudah dijalankan di Supabase
Input protection	Sanitasi HTML/text, validasi email, kode perusahaan, ID, GPS, file, password.	Aktif
Brute-force defense	Rate limit browser dan rate limit server PHP melalui tabel login attempts.	Aktif, tetapi browser-only dapat dilewati
Password	Supabase mengelola password; sistem PHP memakai <code>password_hash</code> / <code>password_verify</code> .	Aktif
HTTP security	CSP, HSTS, X-Frame-Options, nosniff, Referrer Policy, Permissions Policy.	Aktif
CSRF	Token CSRF dan header khusus untuk jalur backend PHP.	Aktif terutama pada endpoint PHP
Monitoring	Audit log lokal/Supabase, Sentry opsional, webhook alert.	Aktif sesuai konfigurasi
File and location	Validasi file, GPS/geofence, face verification/liveness.	Aktif di sisi aplikasi

PWA	Service worker, cache versioning, skipWaiting, clients.claim, update asset.	Aktif
-----	---	-------

Penggunaan localStorage/sessionStorage

Key/fungsi	Tujuan	Catatan SaaS
absensi_shift_config	Cache konfigurasi shift.	Sebaiknya hanya Supabase shift_configs.
absensi_pwreq	Permintaan perubahan password.	Belum sinkron antar perangkat.
absensi_logs	Cache/fallback log absensi.	Data utama sudah di Supabase, tetapi salinan lokal masih ada.
absensi_security	Rate limit/login security per perangkat.	Dapat dihapus user; perlu rate limit server sebagai pertahanan utama.
__absensi_audit_logs	Audit log lokal.	Jangan dianggap sebagai satu-satunya bukti audit.
Bahasa, Sentry, webhook	Preferensi dan konfigurasi browser.	Wajar lokal, tetapi webhook/DSN perlu pengamanan.
absensi_offline_queue	Antrean absensi saat offline.	Wajar untuk PWA, harus disinkron dan dibersihkan setelah sukses.
CSRF token	Token sesi tab browser.	Wajar disimpan di sessionStorage.
Supabase session	Persistensi login.	Default SDK Supabase menggunakan storage browser.

Hal yang Perlu Diperkuat

1. Pindahkan passwordRequests sepenuhnya ke tabel Supabase.
2. Jadikan shift_configs Supabase sebagai satu-satunya sumber konfigurasi shift.
3. Hapus fallback log sensitif dari localStorage atau enkripsi/cache dengan masa berlaku terbatas.
4. Perketat policy Storage surat dokter berdasarkan company_id dan user/role.
5. Evaluasi policy publik seperti companies_insert_all, shift_insert_all, dan sec_logs_insert.
6. Hapus unsafe-eval dari CSP bila semua library sudah mendukung.
7. Jangan menyimpan service-role key di frontend. Obfuscation Base64/XOR bukan enkripsi.

8. Pastikan validasi final absensi tetap dilakukan server/database, bukan hanya JavaScript browser.

File Referensi

- `security.js` : sanitasi, rate limit, CSRF, audit, Sentry, webhook, backup.
- `supabase_client.js` : Supabase Auth dan operasi data.
- `supabase_schema.sql` : tabel, RLS, policy, trigger, storage.
- `auth.php` dan `config.php` : autentikasi PHP lama, session, prepared statements, headers.
- `vercel.json` : CSP dan security headers deployment.
- `protect.js` : anti-iframe dan penghambat shortcut inspect.
- `service-worker.js` : cache PWA dan update aset.

Dokumen ini adalah ringkasan teknis berdasarkan source project saat dibuat, bukan sertifikasi keamanan atau penetration test.